

PHƯƠNG PHÁP LUẬN VÀ QUY TRÌNH KỸ THUẬT CHUYÊN SÂU

ĐIỀU TRA VÀ PHÒNG CHỐNG MÃ ĐỘC KINSING TRÊN AWS

🛡 Được xây dựng bởi NTD Security Team

METHODOLOGY AND TECHNICAL DEEP DIVE PROCESS

INVESTIGATING AND PREVENTING KINSING MALWARE ON AWS

 Built by NTD Security Team

NỘI DUNG

- I Giới thiệu: Pháp y Kỹ thuật số là gì?
- II Phương pháp luận Pháp y Kỹ thuật số
- III Quy trình Kỹ thuật chuyên sâu: Phản ứng và Phân tích Kinsing
- IV Tự động phát hiện, Đánh giá và Xử lý

AGENDA

- I Introduction: What is Digital Forensics?
- II Digital Forensics Methodology
- III Technical Process: Response and Analysis of Kinsing
- IV Automated Detection, Assessment and Response

I. GIỚI THIỆU: PHÁP Y KỸ THUẬT SỐ LÀ GÌ?

⚠ Bối cảnh thực tế

- Sự cố lây nhiễm mã độc đào tiền ảo Kinsing trên các dự án AWS EC2
- Không xác định được thời điểm xâm nhập ban đầu → mất "thời điểm vàng" để phản ứng
- Thiếu dấu vết ban đầu → phức tạp hóa quá trình khắc phục và đánh giá thiệt hại

🔍 Định nghĩa Pháp y Kỹ thuật số

Ngành khoa học ứng dụng và nhánh của giám định pháp y, chuyên về:

- **Thu thập** bằng chứng kỹ thuật số
- **Bảo tồn** tính toàn vẹn của bằng chứng
- **Phân tích** dữ liệu kỹ thuật số
- **Trình bày** bằng chứng một cách khách quan, khoa học và hợp pháp

🔷 Bản chất và phạm vi

- **Bản chất Khoa học:** Tuân thủ phương pháp đã được kiểm chứng để đảm bảo tính toàn vẹn và xác thực
- **Phạm vi Bằng chứng:** Dữ liệu ổ cứng, dữ liệu bộ nhớ, nhật ký hệ thống, nhật ký mạng, dữ liệu đám mây
- **Vai trò:** Quá trình Root Cause Analysis (RCA) - xác định cách thức, thời điểm và phạm vi bị ảnh hưởng

I. INTRODUCTION: WHAT IS DIGITAL FORENSICS?

⚠ Real-world Context

- **Kinsing cryptocurrency malware** infection on AWS EC2 projects
- Unable to determine initial breach point → lost "golden hour" for response
- Lack of initial evidence → complicated recovery and damage assessment

🔍 Definition of Digital Forensics

Applied science and branch of forensic science specializing in:

- **Collecting** digital evidence
- **Preserving** evidence integrity
- **Analyzing** digital data
- **Presenting** evidence objectively, scientifically and legally

🔷 Nature and Scope

- **Scientific Nature:** Follows peer-reviewed methods to ensure integrity and authenticity
- **Evidence Scope:** Disk data, memory data, system logs, network logs, cloud data
- **Role:** Root Cause Analysis (RCA) - determining how, when, and scope of impact

SỰ KHÁC BIỆT GIỮA AWS FORENSIC VÀ ON-PREMISE FORENSIC



Tính vật lý bị trừu tượng hóa

Không có truy cập vật lý vào ổ cứng. Việc thu thập bằng chứng đĩa được thực hiện thông qua API của AWS (tạo EBS Snapshot).



Dữ liệu dễ biến mất (RAM)

Việc thu thập RAM yêu cầu phải được thực hiện trên **chính EC2 Instance đang chạy** (ví dụ: dùng LiME) trước khi cô lập triệt để.



Nhật ký Nền tảng

Các nhật ký cốt lõi như **CloudTrail** và **VPC Flow Logs** là tài nguyên pháp y quan trọng nhất, cung cấp cái nhìn về hành vi của kẻ tấn công ở cấp độ hạ tầng đám mây.

DIFFERENCES BETWEEN AWS FORENSIC AND ON-PREMISE FORENSIC



Physical Abstraction

No physical access to hard drives. Disk evidence collection is performed through AWS APIs (creating EBS Snapshots).



Volatile Data (RAM)

Memory collection must be performed on the **actual running EC2 Instance** (e.g., using LiME) before complete isolation.



Platform Logs

Core logs like **CloudTrail** and **VPC Flow Logs** are the most critical forensic resources, providing insights into attacker behavior at the cloud infrastructure level.

II. PHƯƠNG PHÁP LUẬN PHÁP Y KỸ THUẬT SỐ

Các nguyên tắc cốt lõi (ACPO Principles)



Bảo toàn Bằng chứng

Nguyên tắc 1

Không sửa đổi dữ liệu trên thiết bị gốc. Truy cập phải được thực hiện bởi nhân viên đủ năng lực. **Áp dụng AWS:** Luôn tạo EBS Snapshot trước khi tương tác với Instance bị nhiễm.



Truy cập Ghi lại

Nguyên tắc 2

Ghi lại mục đích, phương pháp, thời gian và người thực hiện khi truy cập bằng chứng gốc. **Áp dụng AWS:** Sử dụng CloudTrail để ghi lại tất cả hoạt động quản lý.



Chuỗi Lưu giữ

Nguyên tắc 3

Ghi lại và chứng minh bằng chứng được kiểm soát vật lý/lô-gic từ khi thu thập đến khi trình bày. Đảm bảo không có cơ hội bị giả mạo.



Người có Thẩm quyền

Nguyên tắc 4

Người điều tra phải có kiến thức và kỹ năng liên quan. Có khả năng trình bày kết quả trước tòa hoặc hội đồng quản lý.

II. DIGITAL FORENSICS METHODOLOGY

Core Principles (ACPO Principles)



Integrity

Principle 1

No modification to data on original media. Access must be performed by competent personnel. **AWS**

Application: Always create EBS Snapshot before interacting with infected Instance.



Auditability

Principle 2

Record purpose, method, time and personnel when accessing original evidence. **AWS Application:** Use CloudTrail to log all management activities.



Chain of Custody

Principle 3

Document and prove evidence is controlled physically/logically from collection to presentation.

Ensure no opportunity for tampering.



Competence

Principle 4

Investigators must possess relevant knowledge and skills. Capable of presenting results before court or management board.



Mô hình các giai đoạn điều tra (NIST/SANS Integration)

Giai đoạn	Mục tiêu Kỹ thuật	Sản phẩm Đầu ra
 I. Thu thập	Thu thập tất cả dữ liệu dễ bay hơi và dữ liệu bền vững mà không làm thay đổi hệ thống	Memory Dump (LiME), EBS Snapshot, VPC Flow Logs, CloudTrail Logs
 II. Bảo quản	Duy trì tính toàn vẹn của bằng chứng bằng cách sử dụng các hàm băm và lưu trữ an toàn	Giá trị Hash (SHA-256) của Memory Dump và EBS Volume. Lưu trữ bằng chứng trong S3 Bucket đã mã hóa
 III. Phân tích	Khám phá và trích xuất bằng chứng về TTPs của Kinsing (Initial Access, Persistence, C2)	Báo cáo Phân tích File System/Memory (Timeline, IOCs)
 IV. Báo cáo	Trình bày kết quả điều tra một cách rõ ràng, khách quan và có thể hiểu được	Tài liệu Root Cause Analysis (RCA) và Khuyến nghị Khắc phục



Investigation Phase Model (NIST/SANS Integration)

Phase	Technical Objectives	Outputs
 I. Acquisition	Collect all volatile and persistent data without modifying the system	Memory Dump (LiME), EBS Snapshot, VPC Flow Logs, CloudTrail Logs
 II. Preservation	Maintain evidence integrity using hashing and secure storage	Hash values (SHA-256) of Memory Dump and EBS Volume. Store evidence in encrypted S3 Bucket
 III. Analysis	Discover and extract evidence of Kinsing TTPs (Initial Access, Persistence, C2)	File System/Memory Analysis Report (Timeline, IOCs)
 IV. Reporting	Present investigation results clearly, objectively and comprehensibly	Root Cause Analysis (RCA) Document and Remediation Recommendations

III. QUY TRÌNH KỸ THUẬT CHUYÊN SÂU

1. Giai đoạn thu thập chuyên sâu (Advanced Acquisition)



Thu thập Dữ liệu dễ bay hơi

a. Memory Dump

Trước khi cô lập mạng/tắt máy, sử dụng **LiME** để tạo Memory Dump:

```
sudo insmod lime.ko format=raw
path=/mnt/temp_vol/mem.lime
```

Kinsing sử dụng tiến trình ẩn trong bộ nhớ để che giấu C2 và tiến trình đào coin. Bộ nhớ là nguồn duy nhất để phân tích trạng thái thời gian thực.



Thu thập Dữ liệu Bền vững

b. EBS Imaging

Tạo **Snapshot EBS** của tất cả các Volume được gắn. Ghi lại ID Snapshot và Thời gian Tạo. Snapshot là bản sao cô lập, bất biến của ổ đĩa. Nó là bằng chứng gốc, tuân thủ Nguyên tắc 1 (ACPO).



Thu thập Nhật ký Cloud

c. AWS Logs

Tải xuống và bảo quản **CloudTrail Logs** (các hoạt động API AWS) và **VPC Flow Logs** (lưu lượng mạng) trong khoảng thời gian trước khi phát hiện sự cố (ví dụ: 7 ngày).

Phân tích các lệnh API bất thường và lưu lượng mạng C2/khai thác qua VPC Flow Logs.



Cô lập Instance

d. Final Containment

Thay đổi SG thành **DENY ALL** và tắt máy (Stop Instance) sau khi Memory Dump đã hoàn thành. Đóng băng trạng thái cuối cùng của đĩa để đảm bảo không có thay đổi nào được thực hiện sau khi thu thập bằng chứng.

III. TECHNICAL DEEP DIVE PROCESS

1. Advanced Acquisition Phase



Volatile Data Collection

a. Memory Dump

Before network isolation/shutdown, use **LiME** to create Memory Dump:

```
sudo insmod lime.ko format=raw
path=/mnt/temp_vol/mem.lime
```

Kinsing uses hidden processes in memory to conceal C2 and mining processes. Memory is the only source for analyzing real-time state.



Persistent Data Collection

b. EBS Imaging

Create **EBS Snapshot** of all attached volumes. Record Snapshot ID and Creation Time. Snapshot is an isolated, immutable copy of the disk. It's the original evidence, complying with Principle 1 (ACPO).



Cloud Log Collection

c. AWS Logs

Download and preserve **CloudTrail Logs** (AWS API activities) and **VPC Flow Logs** (network traffic) for the period before incident detection (e.g., 7 days). Analyze unusual API commands and C2/exploitation network traffic via VPC Flow Logs.



Instance Isolation

d. Final Containment

Change SG to **DENY ALL** and stop instance after Memory Dump is complete. Freeze the final state of the disk to ensure no changes are made after evidence collection.

2. Giai đoạn phân tích chuyên sâu (In-Depth Analysis)



2.1. Phân tích bộ nhớ

Sử dụng **Volatility Framework** để phân tích Memory Dump:

pslist

pstree

linux_malfind

linux_netscan

linux_strings

Tìm kiếm tiến trình ẩn, kết nối mạng lạ và chuỗi ký tự độc hại trong bộ nhớ.



2.2. Phân tích hệ thống tệp cơ bản

Tạo **Timeline File System** (M-A-C Times) để tái tạo chuỗi sự kiện tấn công.

auth.log

secure log

Cron Jobs

systemd

authorized_keys

Kiểm tra vectơ tấn công ban đầu và cơ chế duy trì truy cập của Kinsing.



2.3. Phân tích bộ nhớ nâng cao

Kỹ thuật Volatility chuyên sâu để phân tích trạng thái hoạt động của Kinsing:

Process Analysis

Network Connections

Data Extraction

Command Recovery

Xác định tiến trình kdevtmpfsi, kết nối C2 và khôi phục lịch sử lệnh shell.



2.4. Phân tích hệ thống tệp nâng cao

Sử dụng **The Sleuth Kit (TSK)** trên Volume EBS Read-Only:

Timeline Creation

Initial Access

Persistence Artefacts

Binary Analysis

Điều tra vectơ tấn công ban đầu, cơ chế duy trì và phân tích binary độc hại.

2. In-Depth Analysis Phase



2.1. Memory Analysis

Using **Volatility Framework** to analyze Memory Dump:

pslist

pstree

linux_malfind

linux_netscan

linux_strings

Detect hidden processes, unusual network connections and malicious strings in memory.



2.2. Basic File System Analysis

Create **File System Timeline** (M-A-C Times) to reconstruct attack chain:

auth.log

secure log

Cron Jobs

systemd

authorized_keys

Check for initial attack vectors and persistence mechanisms of Kinsing.



2.3. Advanced Volatility Analysis

Advanced Volatility techniques to analyze Kinsing's active state:

Process Analysis

Network Connections

Data Extraction

Command Recovery

Identify kdevtmpfsi processes, C2 connections and recover shell command history.



2.4. Advanced File System Analysis

Using **The Sleuth Kit (TSK)** on Read-Only EBS Volume:

Timeline Creation

Initial Access

Persistence Artefacts

Binary Analysis

Investigate initial attack vectors, persistence mechanisms and analyze malicious binaries.

Phân tích bộ nhớ (Volatility Framework)

Kỹ thuật Volatility	Lệnh Phân tích Tiêu biểu	Mục tiêu Phân tích
 Phân tích Tiến trình	linux_pslist linux_pstree linux_malfind linux_proc_maps	Tìm kiếm tiến trình kdevtmpfsi hoặc kinsing và các tiến trình con không rõ nguồn gốc. malfind giúp xác định các khu vực bộ nhớ có code bị tiêm hoặc không thuộc về file Binary gốc.
 Phân tích Kết nối Mạng	linux_netscan linux_sockscan	Xác định các kết nối TCP/UDP đang hoạt động/đã đóng. Đặc biệt tìm kiếm các kết nối Outbound đến các cổng khai thác mở (ví dụ: port 3333, 5555, 7777) và các IP C2 không rõ nguồn gốc.
 Trích xuất Dữ liệu	linux_strings grep	Trích xuất các chuỗi ký tự từ bộ nhớ (Heap/Stack). Tìm kiếm: Tên miền C2, địa chỉ ví tiền ảo (Monero/XMR), lệnh shell (curl, wget, bash -c), và các tệp cấu hình.
 Khôi phục Lệnh Shell	linux_bash linux_cmdline	Khôi phục lịch sử lệnh gần nhất từ bộ nhớ của các tiến trình shell (Bash). Điều này có thể lộ ra các lệnh được sử dụng để tải, giải nén và thực thi Kinsing.

Memory Analysis (Volatility Framework)

Volatility Technique	Typical Analysis Commands	Analysis Objectives
Process Analysis	linux_pslist linux_pstree linux_malfind linux_proc_maps	Find kdevtmpfsi or kinsing processes and unknown child processes. malfind helps identify memory regions with injected code or not belonging to original binary files.
Network Connections	linux_netscan linux_sockscan	Identify active/closed TCP/UDP connections. Specifically look for outbound connections to mining ports (e.g., port 3333, 5555, 7777) and unknown C2 IPs.
Data Extraction	linux_strings grep	Extract character strings from memory (Heap/Stack). Search for: C2 domains, cryptocurrency wallet addresses (Monero/XMR), shell commands (curl, wget, bash -c), and configuration files.
Command Recovery	linux_bash linux_cmdline	Recover recent command history from shell process memory (Bash). This can reveal commands used to download, extract and execute Kinsing.

Phân tích hiện trạng hệ thống tệp nâng cao



a. Tái tạo Dòng thời gian

Sử dụng **mactime** (trong TSK) hoặc **Autopsy** để tạo dòng thời gian thống nhất từ các mốc thời gian MAC:

- Phân tích sự kiện file system trong 72 giờ trước khi CPU tăng đột biến
- Tìm kiếm sự kiện tạo file bất thường trong /tmp/, /var/tmp/, /etc/



b. Điều tra Vectơ Tấn công Ban đầu

Phân tích log để xác định lỗ hổng ban đầu mà Kinsing khai thác:

- **Brute-Force SSH:** Kiểm tra /var/log/auth.log hoặc /var/log/secure
- **Redis RCE:** Tìm chuỗi lệnh config set dir /root/.ssh
- **Lỗ hổng Web/Service:** Kiểm tra OpenFire, Nginx, Apache logs



c. Phân tích Cơ chế Duy trì và Binary độc hại

Kiểm tra kỹ lưỡng các vị trí Kinsing thường thiết lập lại chính nó:

- **Cron Jobs:** /var/spool/cron/ hoặc /etc/cron.d/
- **Systemd:** /etc/systemd/system/ để chạy khi khởi động lại
- **Binary Analysis:** Tính SHA-256, sử dụng strings, binwalk



d. Phân tích Trạng thái Mạng và Public Exposure

Xác định các dịch vụ công khai bị lộ mà Kinsing có thể khai thác:

- **Public Port Analysis:** Kiểm tra các dịch vụ lắng nghe trên 0.0.0.0
- **CVE Verification:** Đối chiếu các dịch vụ công khai với các CVE
- **Redis RCE:** Tìm kiếm các phiên bản Redis không có mật khẩu

Advanced File System Analysis



a. Timeline Creation

Use **mactime** (in TSK) or **Autopsy** to create unified timeline from MAC timestamps:

- Analyze file system events in 72 hours before CPU spike
- Search for unusual file creation events in /tmp/, /var/tmp/, /etc/



b. Initial Access Investigation

Analyze logs to determine initial vulnerability exploited by Kinsing:

- **Brute-Force SSH:** Check /var/log/auth.log or /var/log/secure
- **Redis RCE:** Look for config set dir /root/.ssh commands
- **Web/Service Vulnerability:** Check OpenFire, Nginx, Apache logs



c. Persistence & Malicious Binary Analysis

Thoroughly check locations where Kinsing typically establishes persistence:

- **Cron Jobs:** /var/spool/cron/ or /etc/cron.d/
- **Systemd:** /etc/systemd/system/ to run on reboot
- **Binary Analysis:** Calculate SHA-256, use strings, binwalk



d. Network State & Public Exposure Analysis

Identify publicly exposed services that Kinsing could exploit:

- **Public Port Analysis:** Check services listening on 0.0.0.0
- **CVE Verification:** Cross-reference public services with CVEs
- **Redis RCE:** Look for Redis versions without password protection

IV. TỰ ĐỘNG PHÁT HIỆN, ĐÁNH GIÁ VÀ XỬ LÝ

1. Phòng ngừa chủ động (Proactive Prevention)

Lĩnh vực	Cấu hình Kỹ thuật AWS	Mô tả
 Hardening Mạng	✓ Security Group (SG) Tối thiểu ✓ Chỉ mở Port 22/80/443/6379 tới các dải IP cụ thể ✓ Không mở 0.0.0.0/0 trừ khi bắt buộc	Ngăn chặn Brute-force SSH/Khai thác Redis công khai - Vectơ tấn công chính của Kinsing.
 Quản lý Cấu hình	✓ AWS Systems Manager Patch Manager ✓ Duy trì bản vá tự động cho OS và ứng dụng ✓ Ưu tiên Redis/OpenFire	Đóng các lỗ hổng mà Kinsing khai thác.
 Giảm thiểu đặc quyền	✓ IAM Role cho EC2 theo nguyên tắc Least Privilege ✓ Cấu hình AppArmor/SELinux trên Linux	Hạn chế khả năng Kinsing di chuyển ngang (Lateral Movement) và thực thi các lệnh hệ thống.

IV. AUTOMATED DETECTION, ASSESSMENT AND RESPONSE

1. Proactive Prevention

Area	AWS Technical Configuration	Description
 Network Hardening	✓ Minimal Security Group (SG) ✓ Only open Port 22/80/443/6379 to specific IP ranges ✓ Avoid 0.0.0.0/0 unless absolutely necessary	Prevent Brute-force SSH/Public Redis exploitation - Primary attack vectors for Kinsing.
 Configuration Management	✓ AWS Systems Manager Patch Manager ✓ Maintain automatic patching for OS and applications ✓ Prioritize Redis/OpenFire	Close vulnerabilities that Kinsing exploits.
 Privilege Minimization	✓ IAM Role for EC2 following Least Privilege principle ✓ Configure AppArmor/SELinux on Linux	Limit ability for Kinsing to perform lateral movement and execute system commands.

2. Phát hiện tự động (Automated Detection)



Amazon GuardDuty

⚙️ Cấu hình & Mục tiêu

Kích hoạt tính năng Threat Detection. Đặc biệt kiểm tra các phát hiện liên quan đến:

- **Impact:EC2/CryptocurrencyMining**
- **Backdoor:EC2/C2Activity**

ℹ️ Chi tiết

Phát hiện các kết nối mạng C2 ra bên ngoài và các dấu hiệu đào tiền ảo gần như thời gian thực.



CloudWatch Metrics

⚙️ Cấu hình & Mục tiêu

Tạo Alarm trên chỉ số:

- **CPU Utilization (> 90% liên tục trong 5 phút)**

ℹ️ Chi tiết

Phát hiện dấu hiệu đào tiền ảo (Mining) - Dấu hiệu lâm sàng của Kinsing.



Amazon Inspector

⚙️ Cấu hình & Mục tiêu

Thiết lập quét liên tục:

- **Continuous Scanning** cho các lỗ hổng OS và phần mềm

ℹ️ Chi tiết

Tự động xác định các lỗ hổng phần mềm công khai (CVEs) mà Kinsing nhắm đến.

2. Automated Detection



Amazon GuardDuty

⚙️ Configuration & Objectives

Enable Threat Detection. Particularly check for:

- **Impact:EC2/CryptocurrencyMining**
- **Backdoor:EC2/C2Activity**

📘 Details

Detect external C2 network connections and near real-time cryptocurrency mining indicators.



CloudWatch Metrics

⚙️ Configuration & Objectives

Create Alarm on metrics:

- **CPU Utilization** (> 90% continuously for 5 minutes)

📘 Details

Detect cryptocurrency mining indicators - Clinical signs of Kinsing.



Amazon Inspector

⚙️ Configuration & Objectives

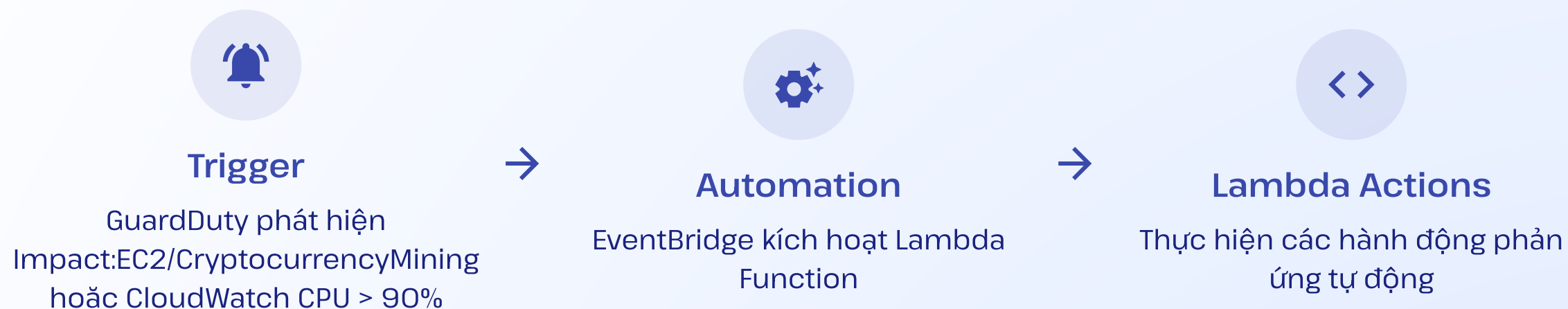
Set up continuous scanning:

- **Continuous Scanning** for OS and software vulnerabilities

📘 Details

Automatically identify public software vulnerabilities (CVEs) that Kinsing targets.

3. Phản ứng tự động (Automated Response)



Σ Hành động Lambda



Ghi lại Hiện trường

Lambda gọi API EC2 để **tạo EBS Snapshot** tức thì của Instance bị nhiễm.



Cô lập

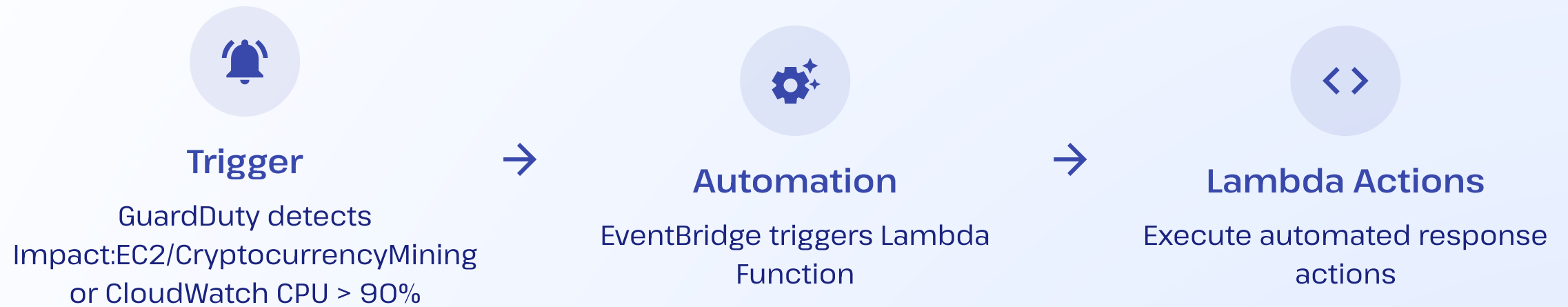
Lambda gọi API EC2 để tự động thay thế Security Group của Instance bị nhiễm bằng một SG **"Isolation" (DENY ALL)**.



Cảnh báo

Gửi thông báo đến kênh liên lạc (SNS/Slack) của đội Forensics/SecOps với thông tin: ID Instance, ID Snapshot, Thời gian.

3. Automated Response



Σ Lambda Actions

Evidence Collection

Lambda calls EC2 API to create **instant EBS Snapshot** of infected instance.

Isolation

Lambda calls EC2 API to automatically replace infected instance's Security Group with an **"Isolation" (DENY ALL)** SG.

Alerting

Send notification to Forensics/SecOps team communication channel (SNS/Slack) with: Instance ID, Snapshot ID, Timestamp.

CẢM ƠN ĐÃ XEM

Xin chân thành cảm ơn sự quan tâm của quý vị!

 Được xây dựng bởi NTD Security Team

 Ý tưởng và đề xuất và xây dựng bởi hung.nguyen17@ntq-solution.com.vn



THANK YOU

Thank you for your attention!

 Built by NTD Security Team

 Idea, proposal and construction by hung.nguyen17@ntq-solution.com.vn

